TRƯỜNG ĐẠI HỌC .....
KHOA CÔNG NGHỆ THÔNG TIN

BÁO CÁO ĐỒ ÁN MÔN HỌC

OSG203 — Hệ điều hành Linux

LINUXADMIN TOOLKIT

Bộ công cụ quản trị, giám sát và bảo vệ máy chủ Linux bằng Bash

Đề tài 3: *Bash Scripting cho System Administration*

Giảng viên hướng dẫn: .....

Lớp: .....

Sinh viên thực hiện: Nguyễn Văn A — MSSV .....
Trần Thị B — MSSV .....
Lê Văn C — MSSV .....

TP. Hồ Chí Minh, tháng ..../2026

Mục lục

1 Giới thiệu **2**

1.1 Bài toán . . . 2
1.2 Ứng dụng thực tế . . . 2
1.3 Kết quả đạt được . . . 2

2 Cơ sở lý thuyết **3**

2.1 Bash scripting . . . 3
2.2 Quản trị Linux liên quan . . . 3
2.3 Sao lưu . . . 3
2.4 Hệ thống phát hiện xâm nhập (IDS) . . . 4

3 Thiết kế **5**

3.1 Năm chức năng . . . 5
3.2 Kiến trúc . . . 5
3.3 Bộ phát hiện xâm nhập . . . 6
3.4 Chống spam cảnh báo . . . 6
3.5 Mô hình triển khai . . . 7

4 Hiện thực và demo **8**

4.1 Triển khai lên máy thật . . . 8
4.2 users — nhân viên và phân quyền . . . 9
4.3 monitor — giám sát . . . 9
4.4 alert — cảnh báo và phát hiện tấn công . . . 10
4.5 backup — sao lưu lên Google Drive . . . 11
4.6 scheduler — systemd . . . 11

5 Kiểm thử và đánh giá **13**

5.1 Kiểm thử tự động . . . 13
5.2 Kết quả vận hành thực tế . . . 14
5.3 Lợi ích của tự động hoá . . . 14
5.4 Hạn chế . . . 14

6 Kết luận **15**

A Hướng dẫn sử dụng **16**

CHƯƠNG 1

Giới thiệu

1.1 Bài toán

Công ty giả định **TechNova Solutions** có một máy chủ Ubuntu tập trung (`technova-core-srv`); lập trình viên, data analyst và tester SSH vào làm việc. **Anh Hưng** — Tech Lead — làm việc từ xa, chỉ dùng terminal qua SSH, cần:

1. cấp quyền và quản lý nhân viên, kể cả khi nghỉ việc;
2. biết ai đang làm gì, ai treo process ngốn CPU/RAM;
3. nhận cảnh báo tức thời khi có sự cố hoặc bị tấn công, kể cả ban đêm;
4. tự động bảo dưỡng và sao lưu, có bản sao nằm ngoài máy chủ.

Làm tay mỗi việc gồm hàng chục lệnh rời rạc, dễ sai và khó lặp lại. Đồ án **tự động hoá toàn bộ bằng Bash**.

1.2 Ứng dụng thực tế

Phù hợp doanh nghiệp nhỏ có vài máy chủ Linux nhưng không có đội IT riêng để vận hành Zabbix, Wazuh hay Veeam. Toolkit xử lý các rủi ro thường gặp: nhân viên nghỉ việc vẫn còn quyền truy cập; bot dò mật khẩu SSH; ổ đầy hoặc process treo lúc nửa đêm; mất dữ liệu do hỏng ổ hay mã độc tống tiền. Toolkit chỉ cần Bash và lệnh có sẵn của Linux, cài bằng một lệnh, giao diện tiếng Việt.

1.3 Kết quả đạt được

- Khoảng **4.370 dòng Bash**, **71 lệnh**, chia thành **5 chức năng**: `users`, `monitor`, `alert`, `backup`, `scheduler`.
- Hai chế độ dùng qua SSH: giao diện menu (TUI) và dòng lệnh (CLI).
- Cài **trực tiếp lên máy Ubuntu thật** và tự vận hành bằng systemd timer; cảnh báo qua Telegram/email; sao lưu lên Google Drive; phát hiện và chặn tấn công SSH.
- Kiểm thử tự động **83/83 PASS**; shellcheck không còn cảnh báo.

Ngoài đề tài 3, toolkit thực hành nội dung của các đề tài 1 (tiến trình), 4 (systemd), 5 (user & bảo mật), 6 (SSH, tường lửa), 9 (giám sát, log) và 10 (cron, cảnh báo email).

CHƯƠNG 2

Cơ sở lý thuyết

2.1 Bash scripting

Bash là shell mặc định của Linux, có biến, điều kiện, vòng lặp, hàm, mảng. Mọi script của toolkit bắt đầu bằng chế độ "nghiêm ngặt":

```
#!/usr/bin/env bash
set -Eeuo pipefail     # dừng khi lỗi, cấm biến chưa khai báo, bắt lỗi trong pipeline
trap 'on_error $LINENO' ERR
```

Các kỹ thuật chính: hàm và mã thoát, `getopts`, mảng kết hợp, biểu thức chính quy, `awk`/`sed` để xử lý log, `trap`, `flock` chống chạy trùng.

2.2 Quản trị Linux liên quan

- **User và quyền:** `/etc/passwd`, `/etc/shadow`, `/etc/group`; quyền *rwx* dạng bát phân; **SGID** (tệp mới kế thừa nhóm của thư mục) và **sticky bit** (chỉ xoá được tệp của mình); sudo; `chage` cho chính sách mật khẩu. Tài khoản có UID 0 có toàn quyền root.
- **Tiến trình:** `ps`, `top`, `kill` (SIGTERM, SIGKILL); bộ lập lịch CFS chia CPU theo giá trị **nice** (-20 đến 19).
- **systemd:** PID 1 sau khi kernel khởi động; quản lý *unit*. Một `.service` mô tả tác vụ, một `.timer` kích hoạt service theo lịch; log được **journald** thu thập (`journalctl -u`).
- **cron / at:** cron chạy định kỳ theo 5 trường *phút giờ ngày tháng thứ*; `at` hẹn chạy một lần.
- **Nhật ký:** journald và rsyslog (`/var/log/auth.log`). Mỗi lần đăng nhập SSH sai để lại dòng như `Failed password ... from <IP>` hoặc, khi máy chỉ cho đăng nhập bằng key, `Invalid user ... [preauth]`.
- **Mạng:** SSH cổng 22; tường lửa netfilter điều khiển bằng `iptables` hoặc `ufw`.

2.3 Sao lưu

Nén `tar`, kiểm tra toàn vẹn bằng **SHA-256**, xoay vòng giữ N bản, và theo **quy tắc 3-2-1**: luôn có một bản ở nơi khác. Toolkit đẩy bản sao lên **Google Drive** bằng `rclone` (xác thực OAuth, chỉ xin quyền `drive.file` — chỉ thấy tệp do nó tạo).

2.4 Hệ thống phát hiện xâm nhập (IDS)

IDS là hệ thống theo dõi để phát hiện dấu hiệu tấn công và cảnh báo. Có hai cách phân loại:

- theo vị trí: **NIDS** soi gói tin mạng (Snort, Suricata); **HIDS** theo dõi chính máy chủ qua log và tệp (OSSEC, Wazuh, fail2ban, AIDE);
- theo cách phát hiện: **dựa trên luật** — so với mẫu tấn công đã biết, kèm ngưỡng; **dựa trên bất thường** — học trạng thái bình thường bằng thống kê hoặc học máy.

Phần lớn IDS dùng thực tế là dựa trên luật vì dễ giải thích và ít báo nhầm. IDS của toolkit là **HIDS dựa trên luật** kết hợp **kiểm tra toàn vẹn tệp** (giống fail2ban + AIDE), **không dùng học máy**.

CHƯƠNG 3

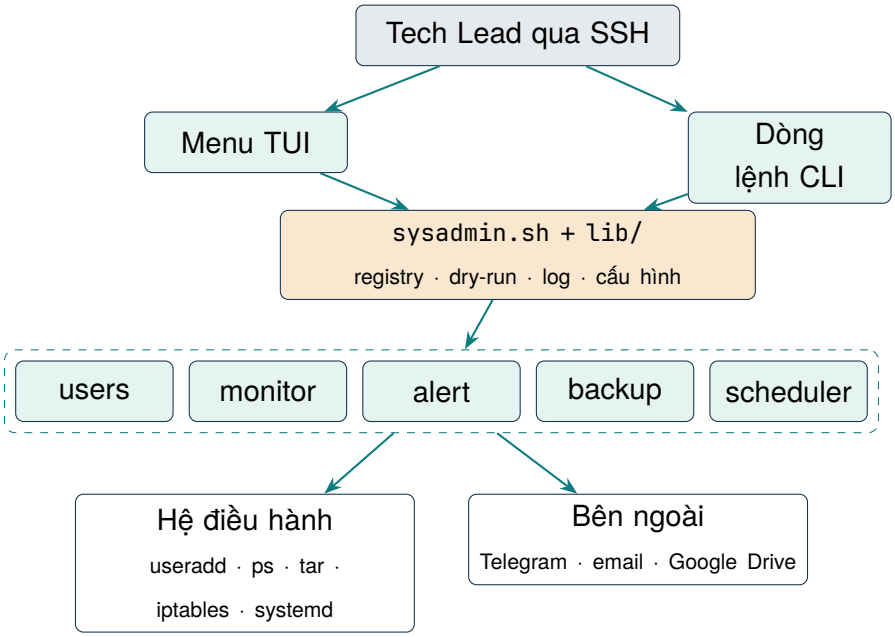
Thiết kế

3.1 Năm chức năng

Bảng 3.1: Chức năng và lệnh chính

Chức năng	Nhu cầu	Lệnh chính
`users`	Quản lý nhân viên, phân quyền	create, setup-dirs, sudo, lock, **offboard**, audit
`monitor`	Ai làm gì, process treo, log	who, usage, **hogs**, renice, kill, **logcheck**, log-upload
`alert`	Cảnh báo sự cố và tấn công	**watch** (thời gian thực), **check**, security, ban/unban, setup-telegram
`backup`	Sao lưu, bản sao trên Drive	**run**, verify, restore, cloud-setup, cloud-list
`scheduler`	Tự động hoá	**timers-install**, install (cron), maintenance

3.2 Kiến trúc



Hình 3.1: Kiến trúc toolkit

- **Giao diện chỉ là lớp vỏ:** chọn chức năng trên menu thì toolkit gọi lại đúng lệnh CLI tương ứng, nên hai chế độ luôn cho cùng kết quả.
- **Registry:** mỗi chức năng khai báo một lần (tên, cần root hay không, tham số); trợ giúp và menu được sinh tự động.

- **An toàn:** thao tác thay đổi hệ thống phải xác nhận; có chế độ chạy thử `--dry-run`; không đụng tới tài khoản hệ thống và PID 1.

3.3 Bộ phát hiện xâm nhập

IDS chạy ở hai tầng: **thời gian thực** — dịch vụ nền `toolkit-ids` (`alert watch`) đọc log xác thực liên tục, xử lý từng dòng ngay khi xuất hiện; và **mỗi phút** — `alert check` so trạng thái hệ thống với bản chuẩn. Hai tầng dùng chung một bộ máy phân tích log, gồm 9 luật:

Bảng 3.2: Các luật phát hiện

Dấu hiệu	Ý nghĩa
Đọc log 10 phút gần nhất	
$\geq$ 5 lần đăng nhập SSH thất bại từ một IP	Dò mật khẩu
$\geq$ 5 tên tài khoản không tồn tại bị thử	Dò tên tài khoản
IP vừa dò mật khẩu **đăng nhập thành công**	Nghi bị chiếm tài khoản
sudo sai nhiều lần; tường lửa chặn nhiều gói từ một IP	Leo thang quyền; quét cổng
So với trạng thái chuẩn (baseline)	
`passwd`, `shadow`, `sudoers`, `sshd_config` đổi checksum	Bị sửa cấu hình
User mới không tạo qua toolkit; user có UID 0	Tài khoản cửa hậu
Cổng mạng mới mở; process chạy từ `/tmp`	Cửa hậu, mã độc

Nếu bật `AUTO_BAN`, IP dò mật khẩu bị chặn bằng tường lửa **trong khoảng 1 giây**, trừ các IP/dải mạng trong `IDS_WHITELIST`. IDS đếm được cả các lần dò khi máy chỉ cho đăng nhập bằng key (đọc dòng `Invalid user`, `[preauth]`), và đếm theo kết nối để không tính trùng. Khi bỏ chặn (`alert unban`), toolkit ghi lại mốc thời gian: các lần thử *trước* mốc không còn được tính nên IP không bị chặn lại oan; nếu IP tấn công tiếp thì bị chặn ngay và báo **CRITICAL "IP tái phạm"**.

3.4 Chống spam cảnh báo

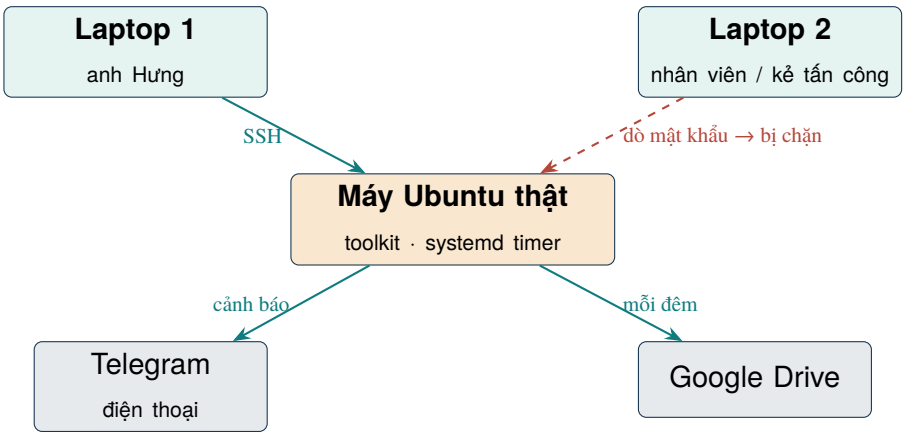
Mọi cảnh báo (tài nguyên và tấn công) đi qua một lớp chống nhiễu chung:

- **Gộp tin:** các sự kiện xảy ra trong 5 giây được gộp thành một tin **[TẤN CÔNG]/[CẢNH BÁO]**.

- **Chỉ báo lại khi nặng thêm:** dấu hiệu đã báo chỉ báo lại khi độ lớn tăng gấp đôi (5 → 10 lần dò) hoặc từ WARN lên CRITICAL; nếu vẫn còn sau 30 phút thì nhắc lại, kèm số lần đã gộp.
- **Giới hạn tốc độ:** tối đa 6 tin / 10 phút, vượt thì gộp vào tin sau; tin CRITICAL luôn được gửi.
- **Xác nhận:** CPU/RAM phải vượt ngưỡng 2 lần kiểm tra liên tiếp mới báo (bỏ qua tăng vọt chốc lát).
- **Bỏ qua sự kiện vô nghĩa:** không báo thêm về IP đã bị chặn; gõ nhầm mật khẩu 1–2 lần rồi vào được không bị coi là bị chiếm tài khoản.

Tất cả ngưỡng trên chỉnh được trong `toolkit.conf` (`ALERT_BATCH_SEC`, `ALERT_ESCALATE`, `ALERT_REPEAT_MIN`, `ALERT_RATE_MAX`, `ALERT_CONFIRM`).

3.5 Mô hình triển khai



Hình 3.2: Bố trí triển khai và demo

Toolkit cài thẳng lên máy Ubuntu thật để quản trị chính máy đó (user, process, log, tường lửa, systemd). Docker chỉ dùng để chạy kiểm thử tự động, vì container chỉ thấy những gì bên trong nó và không có systemd.

CHƯƠNG 4

Hiện thực và demo

Phần này đi theo kịch bản demo *"Một ngày làm việc từ xa của anh Hưng"* (chi tiết từng lệnh: `docs/KICH-BAN-DEMO.md`).

4.1 Triển khai lên máy thật

Một lệnh `sudo ./install.sh --server` cài gói cần thiết, chép toolkit vào `/opt`, hỏi vài câu (thư mục sao lưu, IP tin cậy, có tự chặn IP không, siết SSH), rồi bật một dịch vụ nền và 4 systemd timer:

Bảng 4.1: Lịch tự động

Unit	Lịch	Tác vụ
`toolkit-ids`	chạy liên tục	phát hiện tấn công thời gian thực, tự chặn IP
`toolkit-monitor`	mỗi phút	kiểm tra tài nguyên, toàn vẹn hệ thống, cảnh báo
`toolkit-backup`	02:00	sao lưu + tải log lên Drive
`toolkit-maintenance`	03:30	dọn tệp tạm, log cũ, cache gói
`toolkit-report`	07:00 thứ Hai	báo cáo tuần

CHÈN ẢNH: `hinh/01-install-server.png`

`sudo ./install.sh --server`: phần câu hỏi và dòng "Máy chủ đã sẵn sàng".

Hình 4.1: Triển khai bằng một lệnh

CHÈN ẢNH: `hinh/02-list-timers.png`

`systemctl list-timers 'toolkit-*'` sau vài ngày (cột LAST có giá trị).

Hình 4.2: Bốn timer đã tự chạy nhiều lần

4.2 users — nhân viên và phân quyền

`users create` tạo nhân viên từ `users.csv`: nhóm phòng ban, mật khẩu ngẫu nhiên, bắt đổi mật khẩu ở lần đăng nhập đầu. `users setup-dirs` tạo thư mục phòng ban quyền `2770` (SGID) và thư mục chung `1777` (sticky). `users offboard` xử lý nghỉ việc trong một lệnh: khoá tài khoản, ngắt phiên, thu sudo, xoá crontab, lưu trữ home.

CHÈN ẢNH: `hinh/03-phan-quyen.png`

Laptop 2 đăng nhập `cuonglv`: `ls /srv/technova/dev` bị từ chối; `ls -l /srv/technova/data`.

Hình 4.3: Nhân viên phòng data không vào được thư mục phòng dev

CHÈN ẢNH: `hinh/04-offboard.png`

`sudo sysadmin users offboard binhtt`.

Hình 4.4: Nhân viên nghỉ việc: khoá và ngắt phiên ngay

4.3 monitor — giám sát

`monitor who` cho biết ai đang đăng nhập và từ đâu; `monitor usage` cộng CPU/RAM theo từng nhân viên; `monitor hogs` tìm process vượt ngưỡng; xử lý bằng `renice` hoặc `kill`. `monitor logcheck` tổng hợp log: SSH thất bại theo IP, đăng nhập thành công, sudo, thay đổi tài khoản, dịch vụ lỗi, lỗi kernel.

CHÈN ẢNH: `hinh/05-monitor-hogs.png`

Laptop 2 chạy process nặng; Laptop 1: `sysadmin monitor usage` và `sysadmin monitor hogs`.

Hình 4.5: Phát hiện nhân viên treo process ngốn CPU

4.4 alert — cảnh báo và phát hiện tấn công

`alert check` đo CPU, RAM, ổ đĩa, process treo, dịch vụ lỗi và gọi IDS; có sự cố thì gửi Telegram/email, hết sự cố thì gửi tin "đã ổn định".

CHÈN ẢNH: `hinh/06-alert-check.png`

`sudo sysadmin alert check`.

Hình 4.6: Cảnh báo process ngốn tài nguyên

CHÈN ẢNH:
`hinh/07-telegram-canh-bao.png`
Ảnh chụp màn hình Telegram.

Hình 4.7: Tin cảnh báo trên điện thoại

Demo tấn công: Laptop 2 gõ sai mật khẩu 3 lần rồi đăng nhập đúng (giả định kẻ xấu đoán trúng), sau đó dò hàng loạt tài khoản. Cửa sổ `journalctl -u toolkit-ids -f` trên Laptop 1 hiện ngay cảnh báo chiếm tài khoản, rồi IP bị chặn **giữa chừng** cuộc dò; điện thoại chỉ nhận một tin gộp. Bỏ chặn rồi cho Laptop 2 tấn công lại thì IP bị chặn ngay và được báo là IP tái phạm.

CHÈN ẢNH: `hinh/08-ids-realtime.png`

Laptop 1: `sudo journalctl -u toolkit-ids -f` trong lúc Laptop 2 tấn công (bước 8.4–8.5): dòng NGHI BỊ CHIẾM TÀI KHOẢN và "ĐÃ TỰ ĐỘNG CHẶN".

Hình 4.8: Phát hiện và chặn tấn công thời gian thực

CHÈN ẢNH:
`hinh/09-telegram-tan-cong.png`
Ảnh chụp màn hình Telegram.

Hình 4.9: Tin [TẤN CÔNG] trên điện thoại

CHÈN ẢNH: `hinh/10-alert-banned.png`

`sudo sysadmin alert banned` và `sudo iptables -S INPUT | grep toolkit`.

Hình 4.10: IP tấn công bị chặn bằng iptables

4.5 backup — sao lưu lên Google Drive

`backup run`: nén `tar.gz` → kiểm tra → SHA-256 → giữ 7 bản → tải lên Google Drive (xoá bản cũ hơn 30 ngày) → báo lỗi nếu thất bại. Khôi phục bằng `backup restore`.

CHÈN ẢNH: `hinh/11-backup-run.png`

`sudo sysadmin backup run`.

Hình 4.11: Sao lưu và tải lên Google Drive

CHÈN ẢNH: `hinh/12-drive-backups.png`

Google Drive:

`TechNova-Server/technova-core-srv/backups`.

Hình 4.12: Các bản sao lưu hằng đêm trên Google Drive

4.6 scheduler — systemd

Toolkit tự tạo các unit trong `/etc/systemd/system/`; ví dụ dịch vụ sao lưu:

```
[Service]
Type=oneshot
ExecStart=-/opt/sysadmin-toolkit/sysadmin.sh --yes backup run
ExecStart=/opt/sysadmin-toolkit/sysadmin.sh --yes monitor log-upload
```

CHÈN ẢNH: `hinh/13-journalctl-backup.png`

```
journalctl -u toolkit-backup --since "3 days ago" | tail -20.
```

Hình 4.13: Nhật ký các đêm sao lưu trong journald

CHƯƠNG 5

Kiểm thử và đánh giá

5.1 Kiểm thử tự động

Script `tests/demo-test.sh` chạy trong Docker, mô phỏng trọn một ngày làm việc và kiểm chứng từng bước trên hệ thống của container.

Bảng 5.1: Kết quả kiểm thử tự động

Nhóm	Nội dung	Kết quả
Nền tảng	help, tham số sai, dry-run	5/5
users	tạo nhân viên, phân quyền, SGID, sticky, sudo, khoá, audit	18/18
monitor	process treo, usage, hogs, renice	6/6
alert	phát hiện sự cố, chống gửi trùng, "đã ổn định"	7/7
IDS	dò mật khẩu (cả khi chỉ dùng key), chiếm tài khoản, tệp bị sửa, UID 0, process /tmp, chặn/bỏ chặn IP	16/16
IDS thời gian thực	chặn IP trong vài giây, leo thang, gộp tin, unban không chặn oan, IP tái phạm	8/8
backup	checksum, khôi phục, xoay vòng, tải lên Drive	10/10
scheduler	cron, bảo dưỡng	7/7
Nghỉ việc, dọn dẹp	kick, offboard, xoá dữ liệu demo	6/6
Tổng		**83/83**

Ngoài ra đã thử `install.sh --server` trên Ubuntu 24.04 có systemd thật: dịch vụ `toolkit-ids` tự chạy, đọc journald và chặn IP khoảng 1 giây sau lần dò thứ năm; timer chạy đúng lịch.

CHÈN ẢNH: `hinh/14-test-pass.png`

Dòng "KẾT QUẢ: 83/83 PASS".

Hình 5.1: Kết quả bộ kiểm thử

5.2 Kết quả vận hành thực tế

Bảng 5.2: Số liệu sau thời gian máy chủ tự vận hành

Máy chủ	**[điền: Ubuntu, CPU, RAM]**
Thời gian vận hành	**[điền: số ngày]**
Số bản sao lưu / gói log trên Drive	**[điền: số]**
Số cảnh báo đã gửi	**[điền: số]**
Số lần đăng nhập SSH thất bại / số IP bị chặn	**[điền: số]**

5.3 Lợi ích của tự động hoá

Bảng 5.3: Làm tay so với dùng toolkit

Công việc	**Làm tay**	**Toolkit**
Tạo 7 nhân viên + phân quyền	$\approx$ 50 lệnh, 20–30 phút	2 lệnh, vài giây
Phát hiện sự cố lúc 2 giờ sáng	Chờ người phản ánh	Báo trong $\leq$ 1 phút
Phát hiện dò mật khẩu SSH	Gần như không ai đọc log	Tự chặn trong $\approx$ 1 giây
Sao lưu ra ngoài máy	Dễ quên, không kiểm tra	Tự động mỗi đêm, có checksum
Nhân viên nghỉ việc	Dễ sót bước	1 lệnh, 5 bước

5.4 Hạn chế

Chỉ quản lý một máy chủ; IDS dựa trên luật và ngưỡng cố định nên không bắt được kiểu tấn công chưa có luật; whitelist theo dải mạng mới hỗ trợ IPv4.

CHƯƠNG 6

Kết luận

Đồ án đã xây dựng và triển khai thực tế một bộ công cụ Bash tự động hoá công việc quản trị hằng ngày của máy chủ doanh nghiệp: quản lý nhân viên, giám sát, cảnh báo, phát hiện tấn công, sao lưu ra đám mây và bảo dưỡng bằng systemd.

Hướng phát triển: phát hiện bất thường bằng thống kê (giờ và IP đăng nhập lạ của từng nhân viên); quản lý nhiều máy chủ; mã hoá bản sao lưu bằng GPG; dashboard web.

PHỤ LỤC A

Hướng dẫn sử dụng

```
# Cài đặt trên máy Ubuntu
git clone https://github.com/duylmaoxd/technova-sysadmin-toolkit.git
cd technova-sysadmin-toolkit && sudo ./install.sh --server
sudo sysadmin alert setup-telegram      # nhận cảnh báo trên điện thoại
sudo sysadmin backup cloud-setup        # Google Drive (trước đó: rclone authorize "drive")
sudo sysadmin users create              # tạo nhân viên từ config/users.csv

# Dùng hằng ngày (từ máy khác: ssh hungnv@<IP máy chủ>)
sudo sysadmin --tui                     # giao diện menu
sysadmin monitor who | usage | hogs     # ai đang làm gì, ai ngốn tài nguyên
sudo sysadmin monitor logcheck          # log 24 giờ qua
sudo sysadmin alert security            # kiểm tra tấn công
sudo sysadmin alert ban <IP>            # chặn IP (unban, banned)
sudo sysadmin backup run                # sao lưu ngay
sudo sysadmin users offboard <user>     # nhân viên nghỉ việc
```

Hướng dẫn đầy đủ: `HUONG-DAN-SU-DUNG.md`. Mã nguồn: `https://github.com/duylmaoxd/technova-sysadm`